

Security & Compliance Procedures v1.0

AI-Powered Healthcare Platform

Document Control

- **Version:** 1.0
 - **Date:** August 2025
 - **Classification:** Confidential - Security Sensitive
 - **Compliance Standards:** HIPAA, HITECH, SOC 2 Type II, ISO 27001
 - **Review Cycle:** Quarterly
-

Executive Summary

This document establishes comprehensive security and compliance procedures for the AI-powered healthcare platform. It provides detailed implementation steps for HIPAA compliance, security controls, incident response, and ongoing compliance monitoring. All procedures are designed to exceed regulatory requirements while maintaining operational efficiency.

Critical Compliance Requirements:

- Full HIPAA Privacy and Security Rule compliance
 - HITECH Act breach notification requirements
 - State-specific healthcare regulations
 - PCI DSS for payment processing
 - SOC 2 Type II attestation
-

1. HIPAA Compliance Framework

1.1 Administrative Safeguards

Security Officer Designation

yaml

Role: Chief Security Officer (CSO)

Responsibilities:

- Oversee HIPAA Security Rule implementation
- Conduct annual risk assessments
- Manage security incident response
- Coordinate security training programs
- Maintain security documentation

Backup: Deputy Security Officer

Escalation: CEO / Board of Directors

Review: Quarterly security reviews

Workforce Security Procedures

yaml

Pre-Employment Screening:

- Criminal background check (7 years)
- Identity verification (I-9, SSN validation)
- Reference checks (minimum 2)
- Drug screening (where legally permitted)
- Signed confidentiality agreement

Access Authorization Process:

1. Manager submits access request via JIRA
2. Security team reviews role requirements
3. Minimum necessary access principle applied
4. Identity verification completed
5. MFA enrollment required
6. Access granted with audit logging
7. Quarterly access review scheduled

Termination Procedures:

- **Immediate:** Disable all system access
- **Within 2 hours:** Retrieve company devices
- **Within 24 hours:** Revoke physical access
- **Within 48 hours:** Complete exit interview
- **Within 72 hours:** Final access audit

Information Access Management

python

```
# Role-Based Access Control Matrix
```

```
access_matrix = {  
    "physician": {  
        "patient_records": "full_access",  
        "clinical_notes": "read_write",  
        "prescriptions": "create_sign",  
        "billing": "view_only",  
        "admin_settings": "none"  
    },  
    "medical_assistant": {  
        "patient_records": "read_write",  
        "clinical_notes": "read_create",  
        "prescriptions": "prepare_only",  
        "billing": "view_only",  
        "admin_settings": "none"  
    },  
    "billing_staff": {  
        "patient_records": "demographics_only",  
        "clinical_notes": "none",  
        "prescriptions": "none",  
        "billing": "full_access",  
        "admin_settings": "none"  
    },  
    "patient": {  
        "patient_records": "own_records_only",  
        "clinical_notes": "read_only_own",  
        "prescriptions": "view_own",  
        "billing": "view_own",  
        "admin_settings": "patient_preferences"  
    }  
}
```

Security Training Program

```
yaml
```

Initial Training (Day 1):

Duration: 4 hours

Topics:

- HIPAA fundamentals
- PHI identification and handling
- Security policies and procedures
- Password and authentication requirements
- Incident reporting procedures
- Social engineering awareness

Assessment: Required 80% pass rate

Certification: Annual renewal required

Ongoing Training:

Frequency: Quarterly

Duration: 1 hour

Delivery: Online modules with tracking

Topics:

- **Q1:** Phishing and email security
- **Q2:** Physical security and clean desk
- **Q3:** Mobile device and remote work
- **Q4:** Annual HIPAA refresher

Specialized Training:

Developers: Secure coding practices (monthly)

Administrators: Security tools and monitoring (bi-weekly)

Executives: Compliance and risk management (quarterly)

1.2 Physical Safeguards

Facility Access Controls

yaml

Data Center Requirements:

- SOC 2 Type II certified facilities only
- 24/7 security personnel
- Biometric access controls
- Security cameras with 90-day retention
- Environmental monitoring (temperature, humidity)
- Redundant power and cooling systems

Office Security:

Access Zones:

Zone 1 - Public (Reception):

- Visitor badge required
- Escort required beyond reception

Zone 2 - General Office:

- Employee badge access
- Tailgating detection
- Clean desk policy enforced

Zone 3 - Secure Areas (Server rooms, records):

- Biometric + badge access
- Access logged and reviewed daily
- No unauthorized devices
- Video surveillance 24/7

Workstation Security:

- Automatic lock after 10 minutes idle
- Privacy screens required in open areas
- Cable locks for laptops
- Encrypted hard drives mandatory
- No PHI on local workstations

Device and Media Controls

yaml

Device Management:

Inventory Tracking:

- Asset tags on all devices
- MDM enrollment required
- Quarterly inventory audit
- Immediate reporting of lost/stolen devices

Disposal Procedures:

- **Hard drives:** NIST 800-88 secure wipe
- **SSDs:** Physical destruction required
- **Paper:** Cross-cut shredding (P-4 standard)
- Certificates of destruction maintained

Media Re-use:

- Complete sanitization required
- Verification scan mandatory
- Re-certification before re-deployment
- Audit trail maintained

Encryption Standards:

Data at Rest: AES-256-GCM

Data in Transit: TLS 1.3 minimum

Key Management: Google Cloud KMS

Key Rotation: Every 90 days

Emergency Access: Dual-control key escrow

1.3 Technical Safeguards

Access Control Implementation

javascript

```
// Multi-Factor Authentication Configuration
```

```
const mfaConfig = {  
  required: true,  
  methods: ['authenticator_app', 'sms', 'hardware_token'],  
  
  policyRules: {  
    physicians: {  
      methods: ['authenticator_app', 'hardware_token'],  
      reAuthRequired: 'daily',  
      sessionTimeout: '8_hours'  
    },  
    administrative: {  
      methods: ['hardware_token'],  
      reAuthRequired: 'per_sensitive_action',  
      sessionTimeout: '2_hours'  
    },  
    patients: {  
      methods: ['authenticator_app', 'sms'],  
      reAuthRequired: 'weekly',  
      sessionTimeout: '30_minutes'  
    }  
  },  
  
  exemptions: [], // No exemptions allowed  
  
  backupCodes: {  
    quantity: 10,  
    complexity: 'alphanumeric_12_char',  
    singleUse: true,  
    expiration: '90_days'  
  }  
};
```

```
// Automatic Logoff Configuration
```

```
const sessionConfig = {  
  idleTimeout: {  
    clinical_systems: 600, // 10 minutes  
    admin_systems: 300, // 5 minutes  
    patient_portal: 1800 // 30 minutes  
  },  
  
  warningPeriod: 60, // 1 minute warning
```

```
reauthentication: {  
  prescriptions: 'always',  
  clinical_notes_signing: 'always',  
  phi_export: 'always',  
  settings_change: 'always'  
}  
};
```

Audit Controls

sql

-- Audit Log Schema

CREATE TABLE audit_logs (

log_id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
timestamp TIMESTAMPTZ NOT NULL DEFAULT NOW(),
user_id VARCHAR(255) NOT NULL,
tenant_id VARCHAR(255) NOT NULL,
session_id VARCHAR(255) NOT NULL,

-- Action details

action_type VARCHAR(50) NOT NULL, -- CREATE, READ, UPDATE, DELETE, PRINT, EXPORT
resource_type VARCHAR(50) NOT NULL, -- PATIENT, CLINICAL_NOTE, PRESCRIPTION, etc.
resource_id VARCHAR(255),

-- PHI access indicator

phi_accessed BOOLEAN NOT NULL,
phi_fields TEXT[], -- Specific fields accessed

-- Context

ip_address INET NOT NULL,
user_agent TEXT,
application VARCHAR(100),

-- Security

authentication_method VARCHAR(50),
mfa_used BOOLEAN,

-- Results

success BOOLEAN NOT NULL,
error_code VARCHAR(50),
error_message TEXT,

-- Compliance

legitimate_relationship BOOLEAN,
treatment_purpose BOOLEAN,
minimum_necessary BOOLEAN,

-- Indexes for performance

INDEX idx_user_timestamp (user_id, timestamp),
INDEX idx_resource (resource_type, resource_id),
INDEX idx_phi_access (phi_accessed, timestamp),
INDEX idx_tenant (tenant_id, timestamp)

);

-- Audit Review Procedures

```
CREATE TABLE audit_reviews (  
  review_id UUID PRIMARY KEY DEFAULT gen_random_uuid(),  
  review_date DATE NOT NULL,  
  reviewer_id VARCHAR(255) NOT NULL,  
  review_type VARCHAR(50), -- DAILY, WEEKLY, MONTHLY, INCIDENT  
  
  findings JSONB,  
  anomalies_detected INTEGER DEFAULT 0,  
  actions_required TEXT[],  
  
  status VARCHAR(50), -- PENDING, COMPLETED, ESCALATED  
  resolution_date DATE,  
  resolution_notes TEXT  
);
```

Integrity Controls

yaml

Data Integrity Mechanisms:

Transmission Security:

- TLS 1.3 for all connections
- Certificate pinning for mobile apps
- HSTS headers with 1-year max-age
- Perfect forward secrecy enabled

Message Integrity:

- HMAC-SHA256 for API requests
- Request signing with timestamp
- Replay attack prevention (5-minute window)
- Rate limiting per endpoint

Database Integrity:

- Row-level security policies
- Immutable audit tables
- Cryptographic checksums for clinical notes
- Blockchain anchoring for critical records

Backup Integrity:

- Encrypted backups with separate keys
- Checksum verification on restore
- Air-gapped backup copies monthly
- Restore testing quarterly

Transmission Security

nginx

```
# NGINX Security Configuration
```

```
server {
```

```
    listen 443 ssl http2;
```

```
    server_name api.healthplatform.com;
```

```
    # SSL Configuration
```

```
    ssl_certificate /etc/ssl/certs/healthplatform.crt;
```

```
    ssl_certificate_key /etc/ssl/private/healthplatform.key;
```

```
    ssl_protocols TLSv1.3;
```

```
    ssl_ciphers 'TLS_AES_256_GCM_SHA384:TLS_CHACHA20_POLY1305_SHA256';
```

```
    ssl_prefer_server_ciphers off;
```

```
    ssl_session_timeout 1d;
```

```
    ssl_session_cache shared:SSL:10m;
```

```
    ssl_session_tickets off;
```

```
    ssl_stapling on;
```

```
    ssl_stapling_verify on;
```

```
    # Security Headers
```

```
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
```

```
    add_header X-Frame-Options "DENY" always;
```

```
    add_header X-Content-Type-Options "nosniff" always;
```

```
    add_header X-XSS-Protection "1; mode=block" always;
```

```
    add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-inline'" always;
```

```
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
```

```
    # Rate Limiting
```

```
    limit_req_zone $binary_remote_addr zone=api:10m rate=10r/s;
```

```
    limit_req zone=api burst=20 nodelay;
```

```
    # Request Size Limits
```

```
    client_max_body_size 50M; # For file uploads
```

```
    client_body_timeout 60s;
```

```
    client_header_timeout 60s;
```

```
}
```

2. Security Incident Response Plan

2.1 Incident Classification

```
yaml
```

Severity Levels:

Critical (P0):

- Confirmed data breach with PHI exposure
- Ransomware or system-wide compromise
- Complete system outage
- **Response Time:** Immediate (within 15 minutes)

High (P1):

- Suspected data breach
- Targeted attack in progress
- Critical vulnerability actively exploited
- **Response Time:** Within 1 hour

Medium (P2):

- Suspicious activity detected
- Non-critical vulnerability discovered
- Failed authentication spike
- **Response Time:** Within 4 hours

Low (P3):

- Policy violation
- Minor configuration issue
- Isolated suspicious event
- **Response Time:** Within 24 hours

2.2 Incident Response Team

yaml

Core Team:

Incident Commander:

- **Primary:** Chief Security Officer
- **Backup:** VP of Engineering
- **Authority:** Full decision-making power

Technical Lead:

- **Primary:** Senior Security Engineer
- **Backup:** Senior DevOps Engineer
- **Role:** Technical investigation and remediation

Communications Lead:

- **Primary:** VP of Customer Success
- **Backup:** Marketing Director
- **Role:** Internal and external communications

Legal/Compliance Lead:

- **Primary:** General Counsel
- **Backup:** Compliance Officer
- **Role:** Legal requirements and notifications

Clinical Lead:

- **Primary:** Chief Medical Officer
- **Backup:** Clinical Advisory Board Chair
- **Role:** Clinical impact assessment

Extended Team:

- Network Administrator
- Database Administrator
- Customer Support Manager
- Public Relations (external)
- Forensics Consultant (on-call)
- Law Enforcement Liaison

2.3 Incident Response Procedures

yaml

Phase 1 - Detection & Analysis (0-2 hours):

1. Alert received via monitoring/report
2. Incident Commander notified
3. Initial triage and classification
4. Response team activated
5. Evidence preservation initiated
6. Initial impact assessment
7. Communication plan activated

Phase 2 - Containment (2-6 hours):

Short-term Containment:

- Isolate affected systems
- Disable compromised accounts
- Block malicious IPs
- Preserve evidence

Long-term Containment:

- Deploy patches
- Rebuild systems if needed
- Enhanced monitoring
- Temporary controls

Phase 3 - Eradication (6-24 hours):

- Remove malware/threats
- Close vulnerabilities
- Update security controls
- Verify clean systems
- Document root cause

Phase 4 - Recovery (24-72 hours):

- Restore from clean backups
- Gradually return to production
- Intensive monitoring
- Verify normal operations
- User communication

Phase 5 - Post-Incident (72+ hours):

- Complete incident report
- Lessons learned meeting
- Update procedures
- Additional training if needed

- Regulatory notifications
- Customer notifications

2.4 Breach Notification Procedures

yaml

HIPAA Breach Notification Requirements:

Risk Assessment (Immediate):

- Nature and extent of PHI involved
- Unauthorized person who accessed PHI
- Whether PHI was acquired or viewed
- Mitigation actions taken

Individual Notification (Within 60 days):

- Written notification via first-class mail
- Email if individual agreed to electronic
- Substitute notice if contact info outdated
- Phone call for urgent situations

Media Notification (Within 60 days):

- Required if breach affects 500+ individuals
- Prominent media outlet in affected area
- Must include toll-free number

HHS Notification:

- **500+ individuals:** Within 60 days
- **Less than 500:** Annual summary
- Submit via HHS breach portal

Business Associate Notification:

- Notify covered entities immediately
- No later than 60 days
- Provide all required information

3. Data Protection & Encryption

3.1 Encryption Standards

yaml

Data at Rest:

Database Encryption:

Algorithm: AES-256-GCM

Mode: Transparent Data Encryption (TDE)

Key Storage: Google Cloud KMS

Key Rotation: Automatic every 90 days

File Storage Encryption:

Algorithm: AES-256-GCM

Individual File Encryption: Yes

Metadata Encryption: Yes

Key per File: Yes

Backup Encryption:

Algorithm: AES-256-GCM

Separate Key Infrastructure: Yes

Offline Key Storage: Hardware Security Module

Data in Transit:

External Communications:

Protocol: TLS 1.3

Cipher Suites: AEAD only

Certificate: EV SSL Certificate

HSTS: Enforced with preload

Internal Communications:

Service Mesh: Istio with mTLS

Certificate Management: Automatic rotation

Zero Trust: All internal traffic encrypted

API Security:

Authentication: OAuth 2.0 + JWT

Authorization: Token-based with scopes

Rate Limiting: Per endpoint and tenant

Request Signing: HMAC-SHA256

3.2 PHI Data Classification

yaml

Data Classification Levels:

Restricted (PHI):

Examples:

- Patient names and identifiers
- Medical record numbers
- Diagnoses and clinical notes
- Lab results and imaging
- Prescriptions

Controls:

- Encryption required always
- Access on need-to-know basis
- Audit logging mandatory
- Cannot be stored on workstations

Confidential (Business Sensitive):

Examples:

- Employee records
- Financial data
- Contracts and agreements
- Security configurations

Controls:

- Encryption required
- Role-based access
- Standard audit logging

Internal (Operational):

Examples:

- Policies and procedures
- Non-sensitive communications
- Public marketing materials

Controls:

- Standard access controls
- Basic audit logging

Public:

Examples:

- Marketing website
- Public documentation
- Press releases

Controls:

- No special controls required

3.3 Data Loss Prevention (DLP)

python

DLP Policy Configuration

```
dlp_policies = {
    "phi_detection": {
        "patterns": [
            r"\b\d{3}-\d{2}-\d{4}\b", # SSN
            r"\b[A-Z0-9]{10}\b",      # MRN
            r"(?i)\b(diagnosis|diagnosed|prescription|medication)\b",
        ],
        "actions": ["block", "alert", "log"],
        "channels": ["email", "chat", "file_share"]
    },

    "export_controls": {
        "bulk_export_limit": 100, # Records per export
        "require_approval": True,
        "manager_approval_threshold": 50,
        "audit_all_exports": True
    },

    "endpoint_protection": {
        "usb_storage": "blocked",
        "cloud_storage": "restricted",
        "printing": "watermarked",
        "screen_capture": "blocked_for_phi"
    }
}
```

4. Vulnerability Management

4.1 Vulnerability Scanning

yaml

Scanning Schedule:

Infrastructure Scanning:

Frequency: Weekly automated, Monthly authenticated

Tools:

- Qualys VMDR
- Nessus Professional
- OpenVAS

Scope: All production systems

Application Scanning:

Static Analysis (SAST):

Frequency: Every commit

Tools: SonarQube, Checkmarx

Integration: CI/CD pipeline

Dynamic Analysis (DAST):

Frequency: Weekly

Tools: OWASP ZAP, Burp Suite Pro

Scope: All external endpoints

Dependency Scanning:

Frequency: Daily

Tools: Snyk, GitHub Dependabot

Action: Auto-create PRs for patches

Container Scanning:

Build Time: Every image build

Runtime: Continuous

Tools: Twistlock, Anchore

Registry: Google Container Registry

4.2 Patch Management

yaml

Patch Classification:

Critical (0-day, **actively exploited**):

Timeline: Within 24 hours

Approval: Security Officer

Testing: Minimal, hotfix process

High (Remote code execution, **privilege escalation**):

Timeline: Within 72 hours

Approval: Engineering Manager

Testing: Standard test suite

Medium (Information disclosure, **DoS**):

Timeline: Within 7 days

Approval: Team Lead

Testing: Full regression

Low (Minor issues):

Timeline: Next maintenance window

Approval: Standard change process

Testing: Standard procedures

Patch Process:

1. Vulnerability notification received
2. Risk assessment performed
3. Patch identified/developed
4. Testing in staging environment
5. Change advisory board approval
6. Deployment to production
7. Verification and monitoring
8. Documentation updated

4.3 Penetration Testing

yaml

Testing Schedule:

Annual External Penetration Test:

Scope: Full external attack surface

Duration: 2 weeks

Provider: Certified third-party

Methodology: OWASP, PTES

Quarterly Internal Testing:

Scope: Internal network, applications

Duration: 1 week

Provider: Internal security team

Focus: Lateral movement, privilege escalation

Continuous Purple Team:

Frequency: Monthly exercises

Scope: Specific attack scenarios

Participants: Red team + Blue team

Objectives: Improve detection and response

Social Engineering:

Phishing Simulations: Monthly

Vishing Tests: Quarterly

Physical Security: Annually

Success Metrics: <5% click rate

5. Access Control & Identity Management

5.1 Identity and Access Management (IAM)

yaml

Identity Lifecycle:

Onboarding:

1. HR creates employee record
2. Identity provisioned in IdP (Okta)
3. Base permissions assigned per role
4. MFA device enrolled
5. Security training completed
6. Access activated after training

Access Reviews:

Frequency: Quarterly

Scope: All user access rights

Process:

- Manager reviews direct reports
- Data owners review resource access
- Privileged access reviewed by security
- Orphaned accounts identified
- Excessive permissions removed

Offboarding:

Immediate Actions (0-15 minutes):

- Disable IdP account
- Revoke all sessions
- Reset passwords
- Disable VPN access

Short-term (0-2 hours):

- Retrieve company devices
- Remove from distribution lists
- Transfer data ownership
- Update on-call rotations

Long-term (24-48 hours):

- Complete access audit
- Archive user data
- Update documentation
- Final security review

5.2 Privileged Access Management (PAM)

yaml

Privileged Account Types:

Break-Glass Accounts:

Purpose: Emergency access only

Storage: Physical safe with dual control

Usage: Requires incident number

Monitoring: Real-time alerts

Password: Rotated after each use

Service Accounts:

Creation: Requires architecture review

Passwords: Managed by vault (HashiCorp)

Rotation: Automatic every 30 days

Permissions: Least privilege principle

Monitoring: All activity logged

Administrator Accounts:

Separate: From regular user accounts

MFA: Hardware tokens required

Session: Maximum 2 hours

Approval: Manager approval for activation

Audit: All commands logged

Just-In-Time Access:

Request Process:

1. Submit request with justification
2. Manager approval required
3. Time-boxed access granted (max 8 hours)
4. MFA challenge at activation
5. Automatic revocation
6. Activity audit report generated

5.3 Multi-Factor Authentication

javascript


```
// MFA Policy Configuration
```

```
const mfaPolicies = {  
  globalPolicy: {  
    enabled: true,  
    enforcement: 'mandatory',  
    gracePeriod: 0, // No grace period  
  
    factorRequirements: {  
      minimum: 2,  
      allowedFactors: [  
        'password',  
        'totp',      // Time-based OTP  
        'webauthn',  // Hardware keys  
        'push',      // Mobile app push  
        'biometric'  // Face/fingerprint  
      ],  
  
      deniedFactors: [  
        'sms',      // Not NIST compliant for healthcare  
        'email',    // Not secure enough  
        'security_questions' // Easily compromised  
      ]  
    }  
  },  
  
  conditionalPolicies: [  
    {  
      name: 'High Risk Access',  
      conditions: ['privileged_action', 'phi_export', 'new_device'],  
      requirements: {  
        factors: ['password', 'webauthn'],  
        reauthentication: true  
      }  
    },  
    {  
      name: 'API Access',  
      conditions: ['api_key_generation', 'token_refresh'],  
      requirements: {  
        factors: ['password', 'totp'],  
        ipWhitelist: true  
      }  
    }  
  ]  
}
```

```
]
};
```

6. Network Security

6.1 Network Segmentation

```
yaml
```

Network Zones:

DMZ (Demilitarized Zone):

Purpose: Internet-facing services

Components:

- Load balancers
- Web Application Firewall
- API Gateway
- Reverse proxies

Security:

- IPS/IDS monitoring
- DDoS protection
- Rate limiting
- No direct database access

Application Zone:

Purpose: Application servers

Components:

- Kubernetes clusters
- Application services
- Cache servers
- Message queues

Security:

- No direct internet access
- Service mesh (Istio)
- Network policies enforced
- East-west traffic inspection

Data Zone:

Purpose: Database and storage

Components:

- PostgreSQL clusters
- Object storage
- Backup systems
- Data warehouse

Security:

- Most restricted zone
- No internet access
- Encrypted connections only
- Access via bastion only

Management Zone:

Purpose: Administrative access

Components:

- Bastion hosts
- Monitoring systems
- Security tools
- Configuration management

Security:

- VPN access only
- Jump box required
- Session recording
- Time-based access

6.2 Firewall Configuration

yaml

Firewall Rules:

Ingress Rules:

- name: "allow-https"
source: "0.0.0.0/0"
destination: "dmz"
port: 443
protocol: "TCP"
action: "ALLOW"
- name: "allow-healthcheck"
source: "gcp-health-checkers"
destination: "application-zone"
port: 8080
protocol: "TCP"
action: "ALLOW"
- name: "deny-all-default"
source: "*"
destination: "*"
port: "*"
protocol: "*"
action: "DENY"
priority: 65535

Egress Rules:

- name: "allow-api-calls"
source: "application-zone"
destination: "specific-apis"
port: 443
protocol: "TCP"
action: "ALLOW"
- name: "allow-database"
source: "application-zone"
destination: "data-zone"
port: 5432
protocol: "TCP"
action: "ALLOW"
- name: "block-all-default"
source: "*"
destination: "*"
action: "DENY"

priority: 65535

Web Application Firewall (WAF):

Provider: Google Cloud Armor

Rules:

- OWASP Core Rule Set 3.3
- SQL Injection Protection
- XSS Protection
- Rate limiting (1000 req/min)
- Geographic restrictions (US only)
- Bot detection and mitigation

Custom Rules:

- Block known bad IPs
- Block suspicious user agents
- Enforce authentication headers
- Validate content types

6.3 VPN and Remote Access

yaml

VPN Configuration:

Type: Zero Trust Network Access (ZTNA)

Provider: Zscaler Private Access

Authentication:

- SAML 2.0 via Okta
- MFA required (hardware token)
- Device compliance check
- Location verification

Access Policies:

Developers:

- Access to development environment
- Read-only production logs
- No direct database access

Operations:

- Full infrastructure access
- Time-limited (8 hours max)
- Approval required for production

Support:

- Application access only
- Screen recording enabled
- PHI access logged

Executives:

- Dashboard and reports only
- No system access
- Separate executive VPN

Remote Access Security:

Device Requirements:

- Company-managed devices only
- Full disk encryption
- Endpoint protection installed
- Compliance scan passed
- Automatic lock screen

Session Security:

- Session recording for privileged access
- Automatic disconnect after idle
- Clipboard disabled for PHI

- File transfer restricted
- Print disabled

7. Application Security

7.1 Secure Development Lifecycle (SDL)

yaml

Phase 1 - Requirements:

Security Requirements:

- Threat modeling session
- Privacy impact assessment
- Compliance requirements mapping
- Security user stories created

Phase 2 - Design:

Security Architecture Review:

- Data flow diagrams
- Trust boundaries identified
- Encryption requirements
- Authentication/authorization design

Phase 3 - Development:

Secure Coding Practices:

- OWASP Top 10 training
- Secure coding guidelines
- Peer code reviews
- Static analysis on commit

Phase 4 - Testing:

Security Testing:

- Unit security tests
- Integration security tests
- Dynamic application testing
- Penetration testing

Phase 5 - Deployment:

Security Gates:

- No critical vulnerabilities
- Security sign-off required
- Production hardening checklist
- Security monitoring enabled

Phase 6 - Maintenance:

Ongoing Security:

- Vulnerability monitoring
- Security patches
- Incident response
- Regular security reviews

7.2 Secure Coding Standards

python

```
# Input Validation Example
```

```
import re
```

```
from typing import Optional
```

```
import hashlib
```

```
import hmac
```

```
class SecureInputValidator:
```

```
    """HIPAA-compliant input validation"""
```

```
    @staticmethod
```

```
    def validate_ssn(ssn: str) -> Optional[str]:
```

```
        """Validate and hash SSN for storage"""
```

```
        # Remove any formatting
```

```
        ssn_clean = re.sub(r'[^0-9]', '', ssn)
```

```
        # Validate format
```

```
        if not re.match(r'^\d{9}$', ssn_clean):
```

```
            raise ValueError("Invalid SSN format")
```

```
        # Never store plain SSN - use one-way hash
```

```
        salt = os.environ.get('SSN_SALT')
```

```
        hashed = hashlib.pbkdf2_hmac(
```

```
            'sha256',
```

```
            ssn_clean.encode('utf-8'),
```

```
            salt.encode('utf-8'),
```

```
            100000
```

```
        )
```

```
        return hashed.hex()
```

```
    @staticmethod
```

```
    def validate_mrn(mrn: str) -> str:
```

```
        """Validate Medical Record Number"""
```

```
        # Alphanumeric only, 6-20 characters
```

```
        if not re.match(r'^[A-Z0-9]{6,20}$', mrn):
```

```
            raise ValueError("Invalid MRN format")
```

```
        return mrn
```

```
    @staticmethod
```

```
    def sanitize_html(html: str) -> str:
```

```
        """Remove potentially dangerous HTML"""
```

```
        import bleach
```

```
        allowed_tags = ['p', 'br', 'strong', 'em', 'u']
```

```
allowed_attributes = {}
```

```
return bleach.clean(  
    html,  
    tags=allowed_tags,  
    attributes=allowed_attributes,  
    strip=True  
)
```

```
@staticmethod
```

```
def validate_api_signature(  
    payload: bytes,  
    signature: str,  
    secret: str  
) -> bool:  
    """Validate HMAC signature for API requests"""  
    expected_signature = hmac.new(  
        secret.encode('utf-8'),  
        payload,  
        hashlib.sha256  
    ).hexdigest()  
  
    # Constant-time comparison to prevent timing attacks  
    return hmac.compare_digest(signature, expected_signature)
```

```
# SQL Injection Prevention
```

```
class SecureDatabase:
```

```
    """Parameterized queries only - no string concatenation"""
```

```
@staticmethod
```

```
def get_patient(patient_id: str):  
    # NEVER do this:  
    # query = f"SELECT * FROM patients WHERE id = '{patient_id}'"  
  
    # Always use parameterized queries:  
    query = "SELECT * FROM patients WHERE id = %s AND tenant_id = %s"  
    return db.execute(query, (patient_id, current_tenant_id))
```

```
@staticmethod
```

```
def search_patients(search_term: str):  
    # Use full-text search with parameterization  
    query = """  
        SELECT * FROM patients  
        WHERE to_tsvector('english', name) @@ plainto_tsquery('english', %s)
```

```
AND tenant_id = %s
LIMIT 100
.....
return db.execute(query, (search_term, current_tenant_id))
```

7.3 API Security

yaml

API Security Controls:

Authentication:

- OAuth 2.0 with PKCE
- JWT tokens with short expiry (1 hour)
- Refresh tokens rotated on use
- Token binding to IP/device

Rate Limiting:

Global: 10,000 requests/hour

Per User: 1,000 requests/hour

Per Endpoint:

- Login: 5 attempts per 15 minutes
- Search: 100 requests per minute
- Export: 10 requests per hour
- AI Processing: 50 requests per hour

Input Validation:

- Schema validation (OpenAPI 3.0)
- Type checking
- Length limits
- Character whitelisting
- File type validation

Output Security:

- PHI field encryption
- Response filtering per role
- Error message sanitization
- No stack traces in production

CORS Policy:

- Strict origin validation
- No wildcard origins
- Credentials not allowed cross-origin
- Preflight caching limited

8. Compliance Monitoring & Auditing

8.1 Continuous Compliance Monitoring

yaml

Automated Compliance Checks:

Daily:

- Access control reviews
- Failed login attempts
- Privilege escalations
- Data access patterns
- Configuration drift

Weekly:

- Vulnerability scan results
- Patch compliance status
- User access reviews
- Encryption status
- Backup verification

Monthly:

- Policy compliance audit
- Training completion rates
- Incident metrics
- Third-party vendor reviews
- Risk assessment updates

Quarterly:

- Full HIPAA assessment
- Business associate reviews
- Penetration test results
- Disaster recovery test
- Board compliance report

Compliance Dashboard Metrics:

- HIPAA compliance score (target: >95%)
- Security training completion (target: 100%)
- Patch compliance rate (target: >98%)
- Incident response time (target: <1 hour)
- Audit finding closure rate (target: >90%)
- MFA adoption rate (target: 100%)
- Encryption coverage (target: 100%)

8.2 Audit Log Management

python

```
# Centralized Audit Logging System
```

```
class AuditLogger:
```

```
    """HIPAA-compliant audit logging"""
```

```
    def __init__(self):
```

```
        self.destinations = [
```

```
            'cloud_logging', # Primary
```

```
            'siem',          # Security monitoring
```

```
            'cold_storage'   # Long-term retention
```

```
        ]
```

```
    def log_phi_access(
```

```
        self,
```

```
        user_id: str,
```

```
        patient_id: str,
```

```
        action: str,
```

```
        fields_accessed: list,
```

```
        justification: str
```

```
):
```

```
    """Log PHI access with required HIPAA fields"""
```

```
    audit_entry = {
```

```
        'timestamp': datetime.utcnow().isoformat(),
```

```
        'event_type': 'PHI_ACCESS',
```

```
        'user': {
```

```
            'id': user_id,
```

```
            'role': self.get_user_role(user_id),
```

```
            'department': self.get_user_department(user_id)
```

```
        },
```

```
        'patient': {
```

```
            'id': patient_id,
```

```
            'mrn': self.get_patient_mrn(patient_id)
```

```
        },
```

```
        'access': {
```

```
            'action': action, # CREATE, READ, UPDATE, DELETE
```

```
            'fields': fields_accessed,
```

```
            'justification': justification,
```

```
            'legitimate_relationship': self.verify_relationship(
```

```
                user_id, patient_id
```

```
            )
```

```
        },
```

```
        'context': {
```

```
            'ip_address': request.remote_addr,
```



```

        'session_id': session.get('id'),
        'application': request.headers.get('User-Agent'),
        'request_id': request.headers.get('X-Request-ID')
    },
    'security': {
        'mfa_used': session.get('mfa_verified'),
        'encryption': True,
        'classification': 'RESTRICTED'
    }
}

# Write to all destinations
for destination in self.destinations:
    self.write_to_destination(destination, audit_entry)

# Real-time alerting for suspicious activity
if self.is_suspicious(audit_entry):
    self.alert_security_team(audit_entry)

def is_suspicious(self, entry: dict) -> bool:
    """Detect potentially suspicious activity"""

    checks = [
        self.check_unusual_time(entry),    # After hours access
        self.check_excessive_access(entry), # Too many records
        self.check_unauthorized_dept(entry), # Cross-department
        self.check_export_volume(entry),    # Bulk exports
        self.check_failed_attempts(entry)   # Multiple failures
    ]

    return any(checks)

```

8.3 Compliance Reporting

yaml

Required Reports:

HIPAA Compliance Report:

Frequency: Monthly

Recipients: CISO, CEO, Board

Contents:

- Security Rule compliance status
- Privacy Rule compliance status
- Breach risk assessments
- Training compliance
- Audit findings
- Remediation progress

Risk Assessment Report:

Frequency: Quarterly

Recipients: Risk Committee

Contents:

- Threat landscape changes
- Vulnerability assessment
- Risk mitigation status
- Residual risk levels
- Risk appetite alignment

Incident Report:

Frequency: Per incident + Monthly summary

Recipients: Based on severity

Contents:

- Incident details
- Impact assessment
- Response actions
- Root cause analysis
- Preventive measures

Vendor Compliance Report:

Frequency: Quarterly

Recipients: Procurement, Legal

Contents:

- BAA status
- Security assessments
- Incident history
- SLA compliance
- Risk ratings

Regulatory Reporting:

HHS Office for Civil Rights:

- Annual HIPAA attestation
- Breach notifications (as required)
- Audit responses

State Requirements:

- Medical board compliance
- Data breach notifications
- Telehealth compliance

Industry Certifications:

- SOC 2 Type II annual audit
- ISO 27001 surveillance audits
- HITRUST CSF assessment

9. Business Continuity & Disaster Recovery

9.1 Business Impact Analysis

yaml

Critical Systems Priority:

Tier 1 (RTO: 1 hour, RPO: 5 minutes):

- Patient care systems
- Clinical documentation
- E-prescribing
- Emergency access

Tier 2 (RTO: 4 hours, RPO: 1 hour):

- Scheduling system
- Patient portal
- Billing system
- Lab interfaces

Tier 3 (RTO: 24 hours, RPO: 4 hours):

- Analytics platform
- Training systems
- Administrative tools
- Development environments

9.2 Disaster Recovery Procedures

yaml

DR Scenarios:

Data Center Failure:

Detection: Automated monitoring

Response:

1. Automatic failover to secondary region
2. DNS update (automatic)
3. Verify data synchronization
4. Notify stakeholders
5. Monitor performance

Recovery:

1. Assess primary site
2. Plan failback
3. Synchronize data
4. Controlled failback
5. Post-incident review

Ransomware Attack:

Detection: Endpoint detection, unusual encryption

Response:

1. Isolate affected systems
2. Activate incident response team
3. Assess scope of encryption
4. Initiate recovery from clean backups
5. Notify law enforcement

Recovery:

1. Restore from immutable backups
2. Verify data integrity
3. Patch vulnerabilities
4. Enhanced monitoring
5. User notification if required

Data Corruption:

Detection: Data integrity checks

Response:

1. Stop writes to affected systems
2. Identify corruption scope
3. Determine corruption time
4. Restore from point-in-time backup
5. Replay transactions if possible

Recovery:

1. Validate restored data
2. Reconciliation procedures
3. Resume operations

4. Root cause analysis
5. Implement preventive measures

9.3 Backup and Recovery

yaml

Backup Strategy:

Production Databases:

Type: Continuous replication + snapshots

Frequency:

- Replication: Real-time
- Snapshots: Every 4 hours
- Full backup: Daily

Retention:

- Snapshots: 7 days
- Daily: 30 days
- Monthly: 7 years (HIPAA requirement)

Location:

- Primary: Same region, different zone
- Secondary: Different region
- Archive: Cold storage (90+ days)

Application Data:

Type: Incremental backups

Frequency: Every 6 hours

Retention: 30 days

Encryption: AES-256-GCM

Configuration:

Type: Version controlled

Repository: Git (encrypted)

Backup: Daily export

Recovery Testing:

Monthly:

- Random file restoration
- Database table recovery
- Configuration rollback

Quarterly:

- Full application recovery
- Point-in-time recovery test
- Cross-region restoration

Annual:

- Complete disaster recovery drill
- Simulated data center failure
- Ransomware recovery simulation

10. Third-Party Risk Management

10.1 Vendor Assessment

yaml

Vendor Risk Assessment Process:

Initial Assessment:

1. Security questionnaire (SIG Lite)
2. SOC 2 Type II report review
3. HIPAA compliance verification
4. Business Associate Agreement execution
5. Insurance verification (\$5M minimum)

Risk Categories:

Critical (PHI access):

- Full security assessment
- On-site audit rights
- Annual reassessment
- Continuous monitoring

High (Infrastructure):

- Security attestations required
- Quarterly reviews
- Incident notification SLA

Medium (No PHI, business critical):

- Annual questionnaire
- Certification verification

Low (Non-critical):

- Basic due diligence
- Annual review

Business Associate Requirements:

Mandatory Provisions:

- HIPAA compliance attestation
- Breach notification (24 hours)
- Audit rights
- Data return/destruction
- Subcontractor flow-down
- Cyber insurance requirement
- Indemnification clauses

10.2 Supply Chain Security

yaml

Software Supply Chain:

Open Source Management:

- License compliance scanning
- Vulnerability scanning (Snyk)
- SBOM generation for all builds
- Dependency pinning
- Private registry for approved packages

Commercial Software:

- Vendor security assessment
- Update/patch management
- License compliance
- End-of-life planning

Container Security:

- Base image scanning
- Signed images only
- Registry access controls
- Runtime protection

CI/CD Security:

- Signed commits required
- Build environment isolation
- Artifact signing
- Supply chain attestation

11. Security Awareness & Training

11.1 Security Training Program

yaml

New Employee Training:

Day 1 Orientation:

Duration: 2 hours

Topics:

- Security policies overview
- HIPAA basics
- Password and MFA setup
- Acceptable use policy
- Incident reporting

Format: Instructor-led

Assessment: Required (80% pass)

Week 1 Deep Dive:

Duration: 4 hours

Topics:

- PHI handling procedures
- Data classification
- Secure communication
- Physical security
- Social engineering

Format: Online modules

Assessment: Required (85% pass)

Role-Based Training:

Clinical Staff:

- Patient privacy regulations
- Clinical documentation security
- Mobile device security
- Telehealth security

Frequency: Quarterly

Developers:

- Secure coding practices
- OWASP Top 10
- Security testing
- Vulnerability management

Frequency: Monthly

Administrators:

- Privileged access management
- Security tool usage
- Incident response procedures
- Configuration management

Frequency: Monthly

Executives:

- Risk management
- Regulatory requirements
- Incident command
- Board reporting

Frequency: Quarterly

11.2 Security Awareness Campaigns

yaml

Monthly Themes:

January: Password Security

- Strong password creation
- Password manager usage
- MFA importance
- Account security

February: Phishing Awareness

- Email security
- Identifying phishing
- Reporting procedures
- Simulated phishing tests

March: Physical Security

- Clean desk policy
- Visitor procedures
- Device security
- Tailgating prevention

April: Data Protection

- PHI identification
- Proper handling
- Encryption usage
- Data disposal

May: Incident Response

- How to report incidents
- Response procedures
- Lessons learned
- Recovery planning

June: Mobile & Remote Security

- Device security
- VPN usage
- Public Wi-Fi risks
- Home office security

Awareness Activities:

- Security newsletters (monthly)
- Lunch and learn sessions
- Security champions program
- Bug bounty program (internal)
- Security awareness posters

- Screen saver reminders
- Security tip of the day

12. Compliance Checklist

12.1 HIPAA Security Rule Checklist

yaml

Administrative Safeguards:

- ✓ Security Officer designated
- ✓ Workforce security procedures implemented
- ✓ Information access management in place
- ✓ Workforce training completed
- ✓ Access authorization documented
- ✓ Access establishment and modification procedures
- ✓ Security incident procedures
- ✓ Contingency plan developed
- ✓ Evaluation procedures ongoing
- ✓ Business Associate Agreements executed

Physical Safeguards:

- ✓ Facility access controls implemented
- ✓ Workstation use policies enforced
- ✓ Workstation security measures
- ✓ Device and media controls
- ✓ Equipment disposal procedures
- ✓ Media re-use procedures
- ✓ Data backup plan
- ✓ Disaster recovery plan
- ✓ Emergency mode operations plan

Technical Safeguards:

- ✓ Unique user identification
- ✓ Automatic logoff configured
- ✓ Encryption and decryption
- ✓ Audit logs implemented
- ✓ Integrity controls in place
- ✓ Transmission security enabled
- ✓ Access control mechanisms
- ✓ Authentication procedures
- ✓ PHI encryption at rest and transit

12.2 HITECH Act Compliance

yaml

Breach Notification:

- ✓ Risk assessment procedures
- ✓ Individual notification process (60 days)
- ✓ Media notification process (60 days)
- ✓ HHS notification process
- ✓ Documentation requirements
- ✓ Breach log maintenance

Meaningful Use:

- ✓ Electronic prescribing capability
- ✓ Health information exchange
- ✓ Patient portal access
- ✓ Clinical decision support
- ✓ Quality measure reporting

Enforcement:

- ✓ Increased penalty awareness
- ✓ Compliance program enhanced
- ✓ Audit preparedness
- ✓ Corrective action plans

Appendices

Appendix A: Incident Response Contact List

yaml

Internal Contacts:

Security Team:

- **Primary:** security@healthplatform.com
- **On-call:** +1-555-SEC-RITY
- **Escalation:** CISO mobile

Executive Team:

- **CEO:** [Contact]
- **CTO:** [Contact]
- **General Counsel:** [Contact]

External Contacts:

Law Enforcement:

- **FBI Cyber Division:** [Contact]
- **Local Police:** [Contact]

Incident Response:

- **IR Retainer:** [Vendor Contact]
- **Forensics:** [Vendor Contact]

Legal:

- **External Counsel:** [Contact]
- **Cyber Insurance:** [Contact]

Regulatory:

- **HHS OCR:** [Contact]
- **State AG:** [Contact]

Appendix B: Security Tools Inventory

yaml

Security Tools:

- SIEM: Splunk Enterprise Security
- EDR: CrowdStrike Falcon
- Vulnerability Management: Qualys VMDR
- WAF: Google Cloud Armor
- DLP: Google Cloud DLP
- PAM: CyberArk
- Secrets Management: HashiCorp Vault
- Code Analysis: SonarQube, Checkmarx
- Container Security: Twistlock
- Cloud Security: Google Cloud Security Command Center

Appendix C: Regulatory References

- HIPAA Security Rule: 45 CFR §164.302-318
- HIPAA Privacy Rule: 45 CFR §164.500-534
- HITECH Act: Public Law 111-5
- State Medical Practice Acts: [Per state]
- FDA Guidance: Clinical Decision Support Software
- FTC Safeguards Rule: 16 CFR Part 314

Document Approval

Role	Name	Signature	Date
Chief Security Officer			
Chief Technology Officer			
General Counsel			
Chief Executive Officer			

Next Review Date: November 2025 **Document Owner:** Chief Security Officer **Distribution:** All Staff (Controlled)